TP10 : DevSecOps « Shift Left » (secrets, SAST, dépendances, images, GitHub)

Partie 1 : Secrets avec Gitleaks :

1. Lancer Gitleaks sans correction :

```
arij@vagrant:~/vuln-app$ docker run --rm -v "$PWD:/repo" ghcr.io/gitleaks/gitleaks:latest git /repo --verbose

    ○
    │╲
    │ ○
    ○ ▒
    ▒    gitleaks

4:23PM INF 1 commits scanned.
4:23PM INF scanned ~85072 bytes (85.07 KB) in 203ms
4:23PM INF no leaks found
arij@vagrant:~/vuln-app$
```

2.Modifier les fichiers :

```
arij@vagrant:~/vuln-app$ cat .env.example
cat .gitignore
cat src/config.js
cat Dockerfile
JWT_SECRET=change-me
PAYMENT_API_KEY=change-me
DB_PASSWORD=change-me
node_modules/
.env
// ⚠️ TP10 : secrets retirés, lus depuis l'environnement (variables d'env).
// Ces valeurs n'ouvrent aucun accès réel.
module.exports = {
  port: 3000,
  jwt_secret: process.env.JWT_SECRET,
  payment_api_key: process.env.PAYMENT_API_KEY,
  db_password: process.env.DB_PASSWORD,
};
# ⚠️ TP10 : Dockerfile partiellement corrigé (secret retiré pour la Partie 1).
FROM node:14
WORKDIR /app
COPY . .
RUN npm install
EXPOSE 3000
CMD ["npm", "start"]
arij@vagrant:~/vuln-app$
```

3. Relancer Gitleaks apres modification :

```
arij@vagrant:~/vuln-app$ echo "# Faux positifs à ignorer" > .gitleaksignore
arij@vagrant:~/vuln-app$ git add .gitleaksignore
arij@vagrant:~/vuln-app$ git commit -m "chore: add gitleaksignore rules"
[main 137b128] chore: add gitleaksignore rules
 1 file changed, 1 insertion(+)
arij@vagrant:~/vuln-app$ docker run --rm -v "$PWD:/repo" ghcr.io/gitleaks/gitleaks:latest git /repo --verbose

    ○
    │╲
    │ ○
    ○ ▒
    ▒    gitleaks

4:35PM INF 2 commits scanned.
4:35PM INF scanned ~85179 bytes (85.18 KB) in 136ms
4:35PM INF no leaks found
arij@vagrant:~/vuln-app$
```

Partie 2 : Hook pre-commit :

1. installer le hook :

```
arij@vagrant:~/vuln-app$ pipx install pre-commit
  installed package pre-commit 4.7.0, installed using Python 3.12.3
  These apps are now globally available
    - pre-commit
done! ✨ 🌟 ✨
arij@vagrant:~/vuln-app$ pre-commit autoupdate
[https://github.com/gitleaks/gitleaks] updating v8.24.0 -> v8.30.0
```

```
arij@vagrant:~/vuln-app$ git add .pre-commit-config.yaml
arij@vagrant:~/vuln-app$ git commit -m "test: commit secret"
[INFO] Initializing environment for https://github.com/gitleaks/gitleaks.
[INFO] Installing environment for https://github.com/gitleaks/gitleaks.
[INFO] Once installed this environment will be reused.
[INFO] This may take a few minutes...
Detect hardcoded secrets.....................................................Failed
- hook id: gitleaks
- exit code: 1

○
    │\
    │ ○
    ○ ▒
    ▒▒   gitleaks

Finding:     const token = "REDACTED"
Secret:      REDACTED
RuleID:      generic-api-key
Entropy:     5.000000
File:        test-secret.js
Line:        1
Fingerprint: test-secret.js:generic-api-key:1

4:41PM INF 0 commits scanned.
4:41PM INF scanned ~144 bytes (144 bytes) in 57.4ms
4:41PM WRN leaks found: 1
```

2. Le test de blocage

```
arij@vagrant:~/vuln-app$ rm test-secret.js
arij@vagrant:~/vuln-app$ git restore --staged test-secret.js
arij@vagrant:~/vuln-app$ git commit -m "chore: update pre-commit config to v8.30.0"
Detect hardcoded secrets.....................................................Passed
[main 1d209f1] chore: update pre-commit config to v8.30.0
 1 file changed, 1 insertion(+), 1 deletion(-)
arij@vagrant:~/vuln-app$
```

Partie 3 : SAST avec Semgrep

1.Lancer le scan Semgrep (AVANT correction) :

```
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 7 (7 blocking)
 • Rules run: 105
 • Targets scanned: 10
 • Parsed lines: ~100.0%
 • Scan was limited to files tracked by git
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 105 rules on 10 files: 7 findings.
arij@vagrant:~/vuln-app$
```

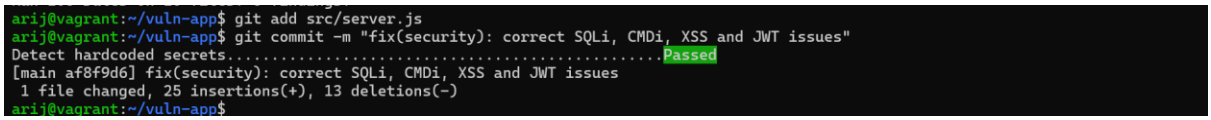
2. Relancer Semgrep (APRÈS correction) :

```
┌──────────────┐
│ Scan Summary │
└──────────────┘
✅ Scan completed successfully.
 • Findings: 5 (5 blocking)
 • Rules run: 105
 • Targets scanned: 10
 • Parsed lines: ~100.0%
 • Scan was limited to files tracked by git
 • For a detailed list of skipped files and lines, run semgrep with the --verbose flag
Ran 105 rules on 10 files: 5 findings.
arij@vagrant:~/vuln-app$
```

Règle	Fichier:ligne	Vrai positif ?	Correction
javascript.express.security.audit.express-sqli	src/server.js:17	Oui	Requête paramétrée db.all(sql,

Règle	Fichier:ligne	Vrai positif ?	Correction
			[req.query.name])
javascript.lang.security.detect-child-process	src/server.js:22	Oui	Utilisation de execFile + validation regex
javascript.express.security.audit.xss	src/server.js:27	Oui	Utilisation de res.json() au lieu de res.send()
javascript.jsonwebtoken.security.jwt-hardcoded-secret	src/server.js:39	Oui	Ajout de expiresIn: "1h"

3. Commiter les corrections :

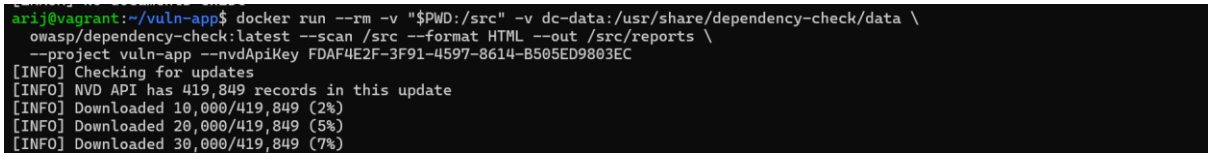


Partie 4 : Dépendances et images

1. Analyser les dépendances avec npm audit (AVANT) :



2. Lancer OWASP Dependency-Check (AVANT) :



```
   About ODC: https://dependency-check.github.io/DependencyCheck/general/internals.html
   False Positives: https://dependency-check.github.io/DependencyCheck/general/suppression.html


[INFO] Analysis Started
[INFO] Finished Archive Analyzer (0 seconds)
[INFO] Finished File Name Analyzer (0 seconds)
[INFO] Finished Node Package Analyzer (0 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Created CPE Index (3 seconds)
[INFO] Finished CPE Analyzer (5 seconds)
[INFO] Finished False Positive Analyzer (0 seconds)
[INFO] Finished NVD CVE Analyzer (0 seconds)
[WARN] An error occurred while analyzing '/src/package-lock.json' (Node Audit Analyzer): Failed to read results from the NPM Audit AP
I (NodeAuditAnalyzer); the analyzer is being disabled and may result in false negatives.
[INFO] Finished Node Audit Analyzer (5 seconds)
[INFO] Finished RetireJS Analyzer (5 seconds)
[WARN] Sonatype OSS Index Analyzer disabled due to missing credentials. Authentication with token is now required, and OSS Index is m
igrating to Sonatype Guide. See https://dependency-check.github.io/DependencyCheck/analyzers/oss-index-analyzer.html for more informa
tion on authentication with Sonatype Guide OSS Index.
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
[INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
[INFO] Finished Dependency Bundling Analyzer (0 seconds)
[INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
[INFO] Analysis Complete (18 seconds)
[INFO] Writing HTML report to: /src/reports/dependency-check-report.html
[ERROR] Failed to read results from the NPM Audit API (NodeAuditAnalyzer); the analyzer is being disabled and may result in false neg
atives.
arij@vagrant:~/vuln-app$
```

3. Construire l'image Docker et l'analyser avec Trivy :

a. *Lancer Trivy sur l'image*

```
arij@vagrant:~/vuln-app$ docker run --rm -v /var/run/docker.sock:/var/run/docker.sock aquasec/trivy:latest \
  image --severity HIGH,CRITICAL vuln-app:1
Unable to find image 'aquasec/trivy:latest' locally
latest: Pulling from aquasec/trivy
ac09fd37397a: Pull complete
9f087194f4fe: Pull complete
d7953b8bb0ca: Pull complete
44136fa355b3: Already exists
6c05e03aa58d: Download complete
dea6bfcf7d25: Download complete
Digest: sha256:8f6bb947dbc528902e11f2f5be52f7b519f6a39d5d148f41166f2040499768fb
Status: Downloaded newer image for aquasec/trivy:latest
2026-11-05T19:35:23Z    INFO    [vulndb] Need to update DB
2026-11-05T19:35:23Z    INFO    [vulndb] Downloading vulnerability DB...
2026-11-05T19:35:23Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
255.24 KiB / 132.37 MiB [>_____________________________________________________] 0.19% ? p/s ?1.03 MiB / 132.37 MiB [>_________
_____________________________________________] 0.78% ? p/s ?1.84 MiB / 132.37 MiB [>_____________________________________________
_____________] 1.39% ? p/s ?2.22 MiB / 132.37 MiB [>_____________________________________________] 1.68% 3.28 MiB p/s ETA 39
s3.06 MiB / 132.37 MiB [->____________________________________________] 2.31% 3.28 MiB p/s ETA 39s3.62 MiB / 132.37 MiB [->_______
_____________________________________] 2.74% 3.28 MiB p/s ETA 39s3.97 MiB / 132.37 MiB [->_____________________________________________
_______] 3.00% 3.26 MiB p/s ETA 39s4.37 MiB / 132.37 MiB [->_____________________________________________] 3.30% 3.26 MiB p/s ETA 3
9s5.03 MiB / 132.37 MiB [->____________________________________________] 3.80% 3.26 MiB p/s ETA 39s5.44 MiB / 132.37 MiB [-->_____
_____________________________________] 4.11% 3.21 MiB p/s ETA 39s6.34 MiB / 132.37 MiB [-->_____________________________________________
________] 4.79% 3.21 MiB p/s ETA 39s7.09 MiB / 132.37 MiB [-->_____________________________________________] 5.36% 3.21 MiB p/s ETA
39s7.62 MiB / 132.37 MiB [-->____________________________________________] 5.76% 3.23 MiB p/s ETA 38s8.12 MiB / 132.37 MiB [--->___
_____________________________________] 6.14% 3.23 MiB p/s ETA 38s8.72 MiB / 132.37 MiB [--->_____________________________________________
_________] 6.59% 3.23 MiB p/s ETA 38s9.56 MiB / 132.37 MiB [--->_____________________________________________] 7.22% 3.24 MiB p/s ETA
 37s10.22 MiB / 132.37 MiB [--->____________________________________________] 7.72% 3.24 MiB p/s ETA 37s10.84 MiB / 132.37 MiB [--->_
_____________________________________] 8.19% 3.24 MiB p/s ETA 37s11.62 MiB / 132.37 MiB [---->_____________________________________________
_________] 8.78% 3.25 MiB p/s ETA 37s12.12 MiB / 132.37 MiB [---->_____________________________________________] 9.16% 3.25 MiB p/s ET
A 37s12.75 MiB / 132.37 MiB [---->_____________________________________________] 9.63% 3.25 MiB p/s ETA 36s13.31 MiB / 132.37 MiB [----
```

b. *Scanner la configuration (Dockerfile)*

```
Dockerfile (dockerfile)
=======================
Tests: 27 (SUCCESSES: 25, FAILURES: 2)
Failures: 2 (UNKNOWN: 0, LOW: 1, MEDIUM: 0, HIGH: 1, CRITICAL: 0)

DS-0002 (HIGH): Specify at least 1 USER command in Dockerfile with non-root user as argument
════════════════════════════════════════
Running containers with 'root' user can lead to a container escape situation. It is a best practice to run containers as non-root use
rs, which can be done by adding a 'USER' statement to the Dockerfile.

See https://avd.aquasec.com/misconfig/ds-0002
────────────────────────────────────────


DS-0026 (LOW): Add HEALTHCHECK instruction in your Dockerfile
════════════════════════════════════════
You should add HEALTHCHECK instruction in your docker container images to perform the health check on running containers.

See https://avd.aquasec.com/misconfig/ds-0026
────────────────────────────────────────
```

4.Corriger (Shift Left)

a. **Corriger les dépendances**

```
16 vulnerabilities (5 low, 10 high, 1 critical)

To address all issues (including breaking changes), run:
  npm audit fix --force
npm warn install-scripts 1 package has install scripts not yet covered by allowScripts:
npm warn install-scripts   sqlite3@5.1.7 (install: node-gyp rebuild)
npm warn install-scripts
npm warn install-scripts Run `npm install-scripts ls` to review, or `npm install-scripts approve <pkg>` to allow.
arij@vagrant:~/vuln-app$ npm install lodash@latest

changed 1 package, and audited 193 packages in 3s

14 packages are looking for funding
  run `npm fund` for details

15 vulnerabilities (5 low, 9 high, 1 critical)

To address all issues (including breaking changes), run:
  npm audit fix --force

Run `npm audit` for details.
npm warn install-scripts 1 package has install scripts not yet covered by allowScripts:
npm warn install-scripts   sqlite3@5.1.7 (install: node-gyp rebuild)
npm warn install-scripts
npm warn install-scripts Run `npm install-scripts ls` to review, or `npm install-scripts approve <pkg>` to allow.
```

a.reconstruire l'image

```
arij@vagrant:~/vuln-app$ docker build -t vuln-app:2 .
[+] Building 19.3s (13/13) FINISHED                                                                                 docker:default
 => [internal] load build definition from Dockerfile                                                                          0.0s
 => => transferring dockerfile: 377B                                                                                          0.0s
 => [internal] load metadata for docker.io/library/node:24-alpine                                                             0.0s
 => [internal] load .dockerignore                                                                                             0.0s
 => => transferring context: 2B                                                                                               0.0s
 => [builder 1/5] FROM docker.io/library/node:24-alpine@sha256:8a32c8cf649a49915a66e81e7a609223c708d0adabf288ee3f4077d765542f8  0.0s
 => => resolve docker.io/library/node:24-alpine@sha256:8a32c8cf649a49915a66e81e7a609223c708d0adabf288ee3f4077d765542f85         0.0s
 => [internal] load build context                                                                                             0.6s
 => => transferring context: 2.75MB                                                                                           0.5s
 => CACHED [builder 2/5] WORKDIR /app                                                                                         0.0s
 => [builder 3/5] COPY package*.json ./                                                                                       0.3s
 => [builder 4/5] RUN npm ci                                                                                                 11.6s
 => [builder 5/5] COPY . .                                                                                                    1.4s
 => [stage-1 3/5] COPY --from=builder /app/package*.json ./                                                                   0.1s
 => [stage-1 4/5] COPY --from=builder /app/node_modules ./node_modules                                                        0.7s
 => [stage-1 5/5] COPY --from=builder /app/src ./src                                                                          0.1s
 => exporting to image                                                                                                        2.9s
 => => exporting layers                                                                                                       1.8s
 => => exporting manifest sha256:5789f96d6aec441a06fd632cfeba4090031082729bcb742bb035dede8f17621b                             0.0s
 => => exporting config sha256:cbc983a9da6223fac45ed5e77ea9043513c0fd774f6af0ffbcaf1ee72db82609                               0.0s
 => => exporting attestation manifest sha256:58ad6f309e2db8241af5c10efe2d4f2b4461b435f9592a4fe4a5f0ec24c85646                 0.0s
 => => exporting manifest list sha256:18a88ed607c270fb74905135e06be8b3bf386aaabd968dd464b3ec42948cd086                        0.0s
 => => naming to docker.io/library/vuln-app:2                                                                                 0.0s
 => => unpacking to docker.io/library/vuln-app:2                                                                              0.9s
```

c. *Scanner l'image corrigée*

```
arij@vagrant:~/vuln-app$ docker run --rm -v /var/run/docker.sock:/var/run/docker.sock aquasec/trivy:latest \
  image --severity HIGH,CRITICAL vuln-app:2
2026-11-05T19:48:21Z    INFO    [vulndb] Need to update DB
2026-11-05T19:48:21Z    INFO    [vulndb] Downloading vulnerability DB...
2026-11-05T19:48:21Z    INFO    [vulndb] Downloading artifact...        repo="mirror.gcr.io/aquasec/trivy-db:2"
191.25 KiB / 132.37 MiB [>_____________________________________________________] 0.14% ? p/s ?639.25 KiB / 132.37 MiB [>_______
_____________________________________________] 0.47% ? p/s ?911.25 KiB / 132.37 MiB [>_____________________________________
____________] 0.67% ? p/s ?1.14 MiB / 132.37 MiB [>_____________________________________________] 0.86% 1.59 MiB p/s ETA 1m22
s1.83 MiB / 132.37 MiB [>_____________________________________________] 1.38% 1.59 MiB p/s ETA 1m22s2.39 MiB / 132.37 MiB [>________
_____________________________________] 1.81% 1.59 MiB p/s ETA 1m21s3.08 MiB / 132.37 MiB [->_____________________________________
_____] 2.32% 1.69 MiB p/s ETA 1m16s3.23 MiB / 132.37 MiB [->_____________________________________________] 2.44% 1.69 MiB p/s ETA 1m1
6s3.51 MiB / 132.37 MiB [->_____________________________________________] 2.66% 1.69 MiB p/s ETA 1m16s3.67 MiB / 132.37 MiB [->______
_____] 2.77% 1.64 MiB p/s ETA 1m18s3.80 MiB / 132.37 MiB [->_____________] 2.87% 1.64 MiB p/s ETA 1m18s3.83 MiB / 132.37 MiB [->_____________] 2.89% 1.64 MiB p/s ETA 1m
18s3.86 MiB / 132.37 MiB [->_____________________________________________] 2.92% 1.56 MiB p/s ETA 1m22s4.01 MiB / 132.37 MiB [->_____
_____] 3.03% 1.56 MiB p/s ETA 1m22s4.17 MiB / 132.37 MiB [->_____________] 3.15% 1.56 MiB p/s ETA 1m22s4.33 MiB / 132.37 MiB [->_____________] 3.27% 1.51 MiB p/s ETA 1
m24s4.45 MiB / 132.37 MiB [->_____________________________________________] 3.36% 1.51 MiB p/s ETA 1m24s4.48 MiB / 132.37 MiB [->_____
_____] 3.39% 1.51 MiB p/s ETA 1m24s4.73 MiB / 132.37 MiB [->_____________] 3.58% 1.46 MiB p/s ETA 1m27s4.95 MiB / 132.37 MiB [->_____________] 3.74% 1.46 MiB p/s ETA
1m27s5.11 MiB / 132.37 MiB [->_____________________________________________] 3.86% 1.46 MiB p/s ETA 1m27s5.11 MiB / 132.37 MiB [->___
_____] 3.86% 1.40 MiB p/s ETA 1m30s5.36 MiB / 132.37 MiB [->_____________] 4.05% 1.40 MiB p/s ETA 1m30s5.58 MiB / 132.37 MiB [->_____________] 4.21% 1.40 MiB p/s ETA
 1m30s5.76 MiB / 132.37 MiB [-->____________________________________________] 4.36% 1.38 MiB p/s ETA 1m31s5.92 MiB / 132.37 MiB [-->_
_____] 4.47% 1.38 MiB p/s ETA 1m31s6.19 MiB / 132.37 MiB [-->_____________] 4.67% 1.38 MiB p/s ETA 1m31s7.11 MiB / 132.37 MiB [-->_____________] 5.37% 1.44 MiB p/s ET
A 1m27s7.87 MiB / 132.37 MiB [-->____________________________________________] 5.95% 1.44 MiB p/s ETA 1m26s8.64 MiB / 132.37 MiB [---
>____________________________________________] 6.53% 1.44 MiB p/s ETA 1m25s9.39 MiB / 132.37 MiB [--->_____________] 7.09% 1.59 MiB p/s ETA 1m17s10.17 MiB / 132.37 MiB [--->____________] 7.68% 1.59 MiB p/s E
TA 1m16s10.92 MiB / 132.37 MiB [--->____________________________________________] 8.25% 1.59 MiB p/s ETA 1m16s11.70 MiB / 132.37 MiB [-
--->____________________________________________] 8.84% 1.74 MiB p/s ETA 1m9s12.45 MiB / 132.37 MiB [---->_____________] 9.41% 1.74 MiB p/s ETA 1m9s13.20 MiB / 132.37 MiB [----->____________] 9.97% 1.74 MiB p/s
 ETA 1m8s13.98 MiB / 132.37 MiB [----->____________________________________________] 10.56% 1.87 MiB p/s ETA 1m3s14.73 MiB / 132.37 MiB [
```

```
| undici (package.json)          | CVE-2026-109383 |          |        | 6.28.0          | 6.29.1, 7.30.1, 8.12.2
|                | undici: undici: Certificate validation bypass via dropped    |
|                | TLS options in Agent                                         |
|                | https://avd.aquasec.com/nvd/cve-2026-109383                  |
|                |-----------------|----------|--------|-----------------|-----------------------------------------|
|                | CVE-2026-109869 |          |        |                 |
|                | undici: undici: Denial of Service via unhandled stream error |
|                | on excessive content...                                      |
|                | https://avd.aquasec.com/nvd/cve-2026-109869                  |
|----------------|-----------------|----------|--------|-----------------|-----------------------------------------|
|                | CVE-2026-19534  |          |        |                 | 6.28.1, 7.29.1, 8.10.2
|                | undici: undici: Denial of Service via unrequested WebSocket  |
|                | subprotocol                                                  |
|                | https://avd.aquasec.com/nvd/cve-2026-19534                   |
|----------------|-----------------|----------|--------|-----------------|-----------------------------------------|
|                | CVE-2026-87018  |          |        |                 | 6.29.1, 7.30.1, 8.12.2
|                | undici: undici: Denial of Service via TLS renegotiation with |
|                | mismatched certificate                                       |
|                | https://avd.aquasec.com/nvd/cve-2026-87018                   |
|________________|_____________________________________________________________|
arij@vagrant:~/vuln-app$
```

d. Scanner la config

```
| Target     | Type       | Misconfigurations |
|------------|------------|-------------------|
| Dockerfile | dockerfile |         1         |

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

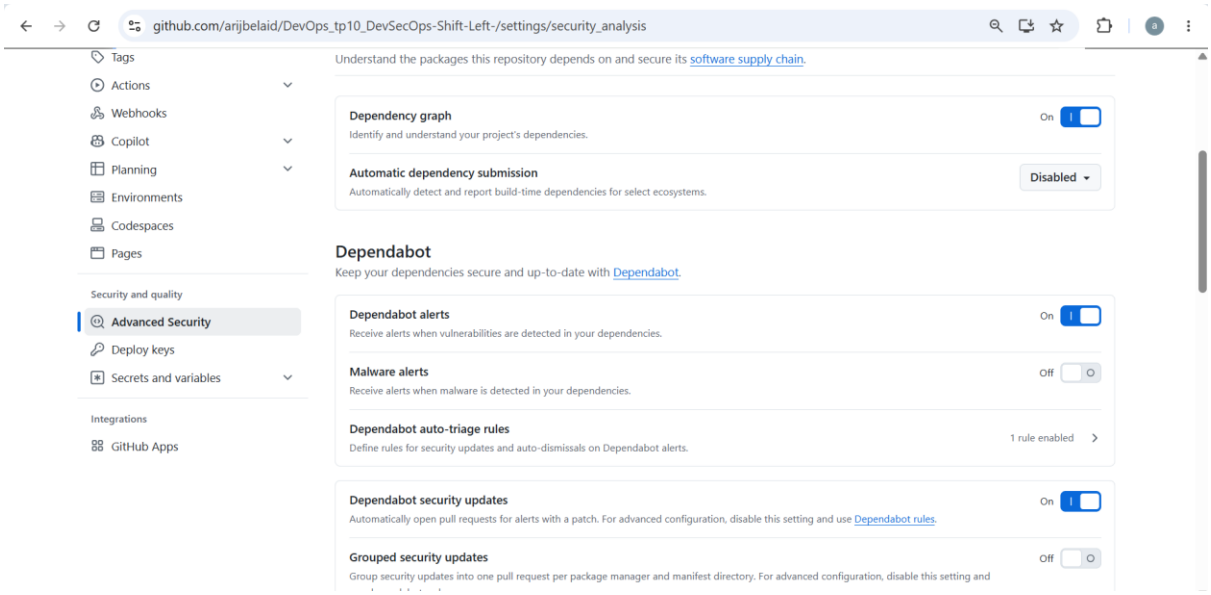

Dockerfile (dockerfile)
=======================
Tests: 27 (SUCCESSES: 26, FAILURES: 1)
Failures: 1 (UNKNOWN: 0, LOW: 1, MEDIUM: 0, HIGH: 0, CRITICAL: 0)

DS-0026 (LOW): Add HEALTHCHECK instruction in your Dockerfile
════════════════════════════════════════
You should add HEALTHCHECK instruction in your docker container images to perform the health check on running containers.

See https://avd.aquasec.com/misconfig/ds-0026
════════════════════════════════════════
```

Partie 5 : GitHub (CodeQL, Dependabot, workflow sécurisé) :

1. Activer les fonctionnalités de sécurité :



2.Ajouter le fichier dependabot

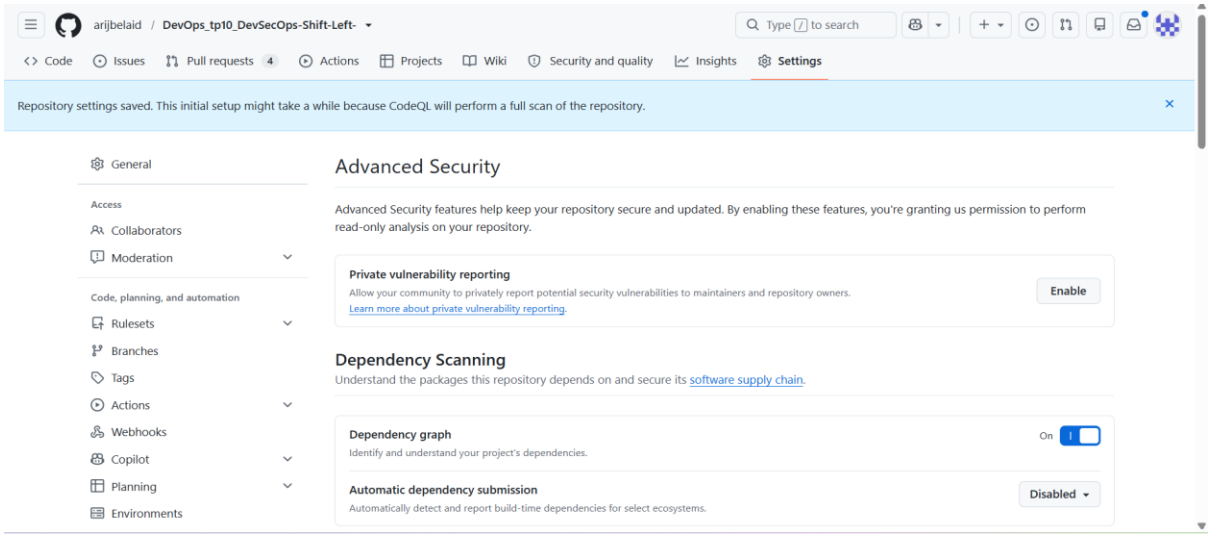
```
 GNU nano 7.2                                        .github/dependabot.yml *
version: 2
updates:
  # Maintenir les dépendances npm à jour
  - package-ecosystem: "npm"
    directory: "/"
    schedule:
      interval: "weekly"

  # Maintenir les Actions GitHub à jour (sécurité de la CI)
  - package-ecosystem: "github-actions"
    directory: "/"
    schedule:
      interval: "weekly"
```

3.pousser sur git

```
arij@vagrant:~/vuln-app$ git add .github/dependabot.yml
git commit -m "ci: add dependabot configuration"
git push origin main
Detect hardcoded secrets.................................................Passed
[main cfd1d61] ci: add dependabot configuration
 1 file changed, 13 insertions(+)
 create mode 100644 .github/dependabot.yml
Enumerating objects: 6, done.
Counting objects: 100% (6/6), done.
Delta compression using up to 4 threads
Compressing objects: 100% (4/4), done.
Writing objects: 100% (4/4), 525 bytes | 175.00 KiB/s, done.
Total 4 (delta 1), reused 0 (delta 0), pack-reused 0
remote: Resolving deltas: 100% (1/1), completed with 1 local object.
remote:
remote: GitHub found 32 vulnerabilities on arijbelaid/DevOps_tp10_DevSecOps-Shift-Left-'s default branch (1 critical, 15 high, 9 mode
rate, 7 low). To find out more, visit:
remote:      https://github.com/arijbelaid/DevOps_tp10_DevSecOps-Shift-Left-/security/dependabot
remote:
To github.com:arijbelaid/DevOps_tp10_DevSecOps-Shift-Left-.git
   e6f7956..cfd1d61  main -> main
arij@vagrant:~/vuln-app$
```

4.Activer CodeQL (Analyse SAST de GitHub) :



5. Le workflow sécurisé :

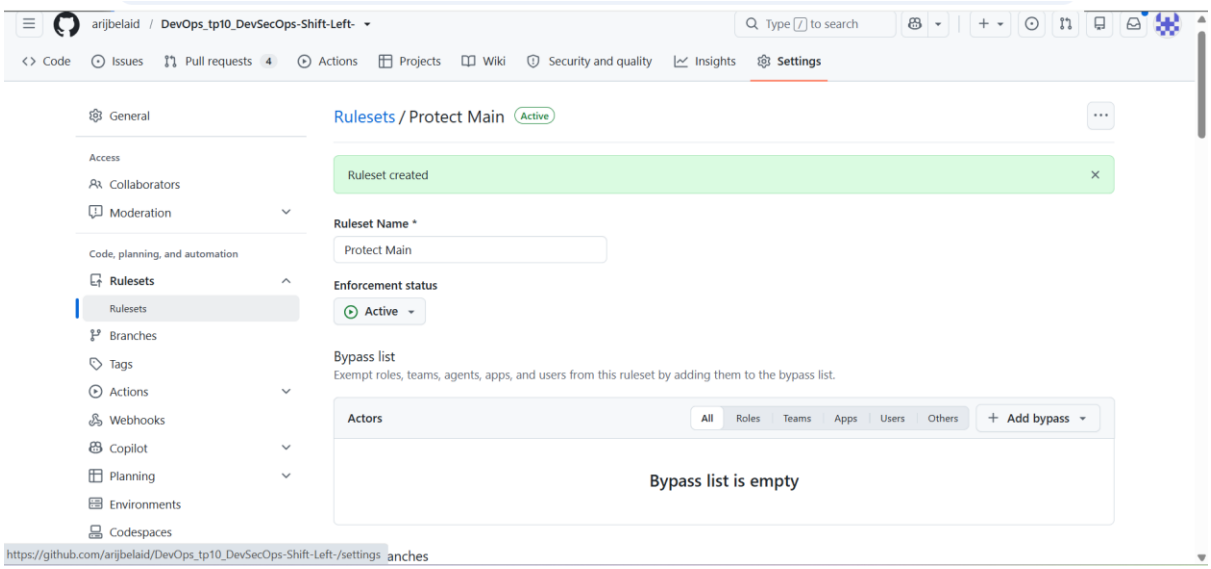
```
 GNU nano 7.2                                    .github/workflows/security.yml *
name: "DevSecOps Pipeline"

on:
  push:
    branches: [ "main" ]
  pull_request:
    branches: [ "main" ]

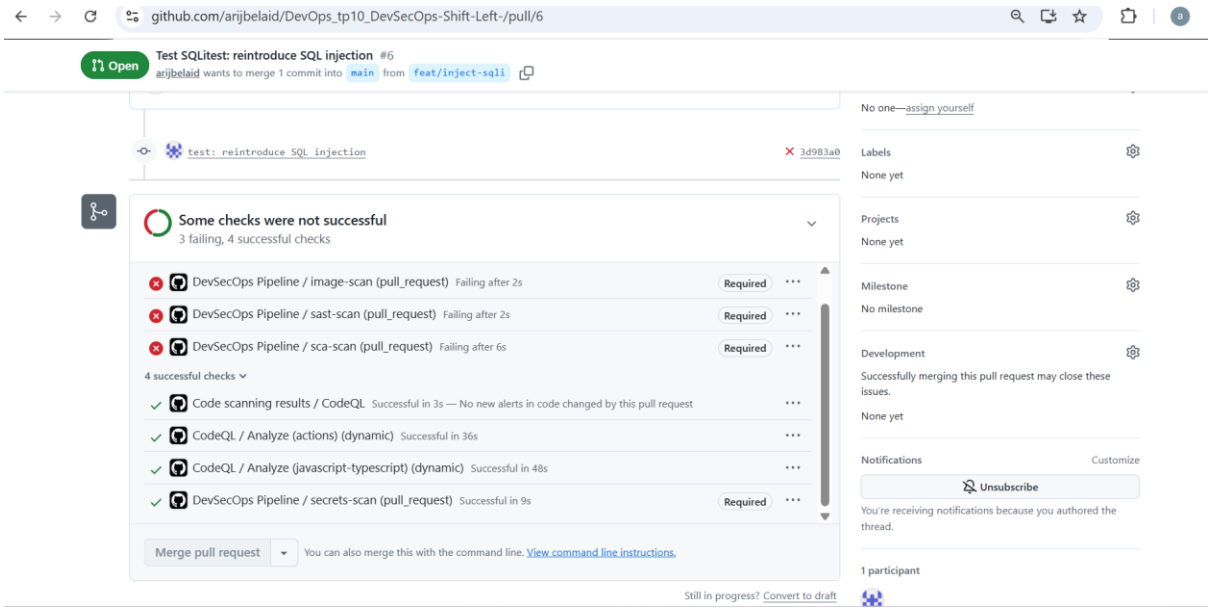
permissions:
  contents: read
  security-events: write

jobs:
  secrets-scan:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@b4ffde65f46336ab88eb53be808477a3936bae11 # v4.1.1
        with:
          fetch-depth: 0
      - name: Gitleaks Scan
        uses: gitleaks/gitleaks-action@v2
        env:
          GITHUB_TOKEN: ${{ secrets.GITHUB_TOKEN }}
```

6. **Protéger la branche main**

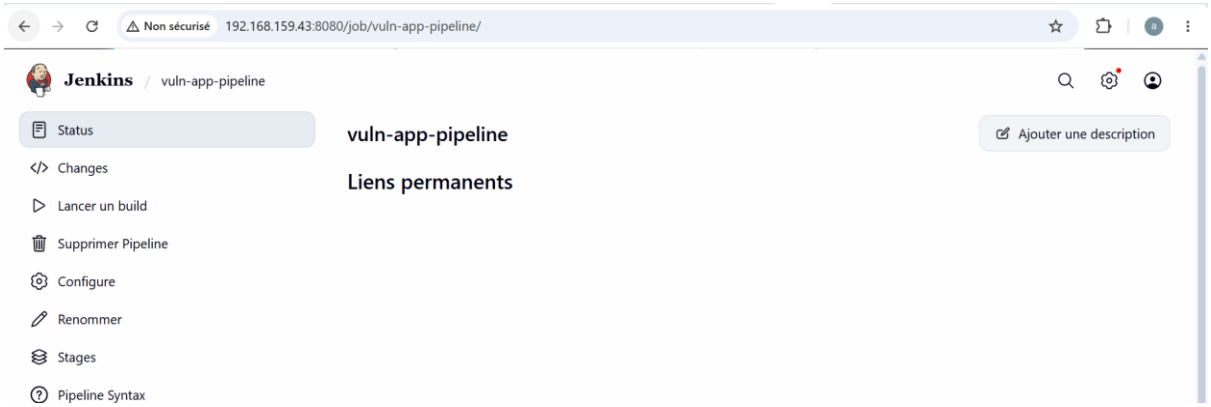


7. Tester

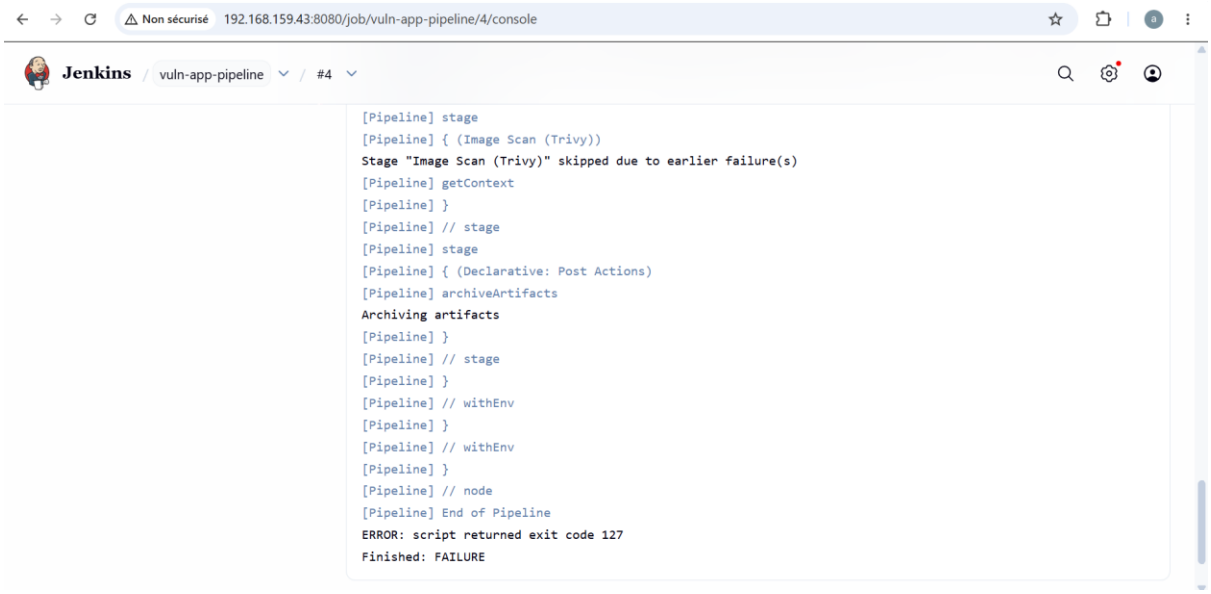


Partie 6 : Quality gates dans Jenkins :

1. Configurer le Job dans Jenkins



2.lancer pipline



3.relancer build apres correction :

